

APEX PAYMENTS INC.

Information Security and Data Protection Policy

Policy Owner: Chief Information Security Officer (CISO) | Classification: Internal | Version 1.0

Effective Date	02 August 2026	Review Cycle	Annual
Applies To	All employees, contractors, systems and data	Approved By	Executive Management

1.0 Purpose and Scope

This policy establishes the minimum information security and data protection requirements for Apex Payments Inc. It applies to all employees, contractors, administrators, applications, infrastructure, databases, and information assets that process, store, or transmit company or customer data. Apex Payments is committed to protecting the confidentiality, integrity, and availability of information while supporting reliable financial services.

Apex Payments guarantees that 100% of customer data is encrypted both in transit and at rest using AES-256. All teams are expected to design and operate systems in accordance with this assurance and to report deviations through the security exception process.

2.0 Access Control and Identity Security

Access to Apex Payments systems shall follow the principles of least privilege and need-to-know. **All employee and administrator accounts require Multi-Factor Authentication (MFA) using company-approved hardware tokens.** Password-only access is prohibited for corporate, production, cloud, database, and administrative systems.

Authorization is governed through a strict **Role-Based Access Control (RBAC) matrix** that maps approved job functions to system privileges. Access rights, privileged roles, inactive accounts, and role assignments are formally reviewed **every 30 days**. Unnecessary or inappropriate access must be revoked promptly, and changes to privileged access must be recorded for audit purposes.

3.0 Data Storage and Protection

Sensitive customer and payment information should be protected throughout its lifecycle, including collection, processing, storage, transmission, archival, and disposal. New systems must use approved cryptographic controls and restrict access to sensitive datasets to authorized personnel and services.

Notwithstanding the encryption commitment stated in Section 1.0, the legacy **transactions_db PostgreSQL database currently stores user credit card numbers and passwords in plain text without encryption or password hashing.** This configuration remains in place because the legacy reporting tools cannot read encrypted data. The database is therefore an acknowledged security exception pending modernization of the reporting environment.

4.0 Backup, Recovery and Business Continuity

System backups are performed automatically **every Sunday at 2:00 AM** to support recovery from accidental deletion, system failure, or operational disruption. Backup completion should be monitored and failures escalated to the infrastructure team.

To reduce infrastructure costs, **the current backups are stored on the same local server rack as the primary database**. This creates a shared physical failure domain between production data and its backup copies. In addition, **restoration testing has not been performed during the last 18 months**. Management acknowledges these limitations and intends to evaluate geographically separate backup storage and a recurring recovery-test schedule.

5.0 Incident Response

Employees and contractors must immediately report suspected security incidents, unauthorized access, data exposure, malware, credential compromise, or abnormal system behavior to the Security Team. The CISO or designated incident commander shall coordinate triage, containment, evidence preservation, eradication, recovery, and post-incident review. Material incidents shall be escalated to executive management and relevant legal or compliance stakeholders.

Security logs and available audit evidence should be preserved during investigations. Lessons learned from significant incidents must be documented and used to improve technical controls, operational procedures, and employee awareness.

6.0 Security Monitoring and Audit

Production systems should generate appropriate authentication, authorization, administrative, and security event logs. Security personnel are responsible for reviewing relevant alerts and investigating suspicious activity. Compliance reviews may include access records, configuration evidence, backup records, incident documentation, and data-protection controls.

7.0 Policy Exceptions and Enforcement

Exceptions to this policy must be documented with a business justification, risk description, responsible owner, and planned remediation date. Approved exceptions do not remove the underlying risk. Violations may result in access suspension, disciplinary action, contract termination, or other corrective measures as appropriate.

8.0 Review and Approval

The CISO shall review this policy at least annually and following material changes to Apex Payments' technology, regulatory obligations, threat environment, or business operations. Material revisions require executive management approval.

Document Note: This fictional policy is intended for controlled compliance and audit-system testing. It intentionally contains differing control states and an internal contradiction for evaluation purposes.